

Fundamentals of Information Systems Security

Chapter 3 Quiz: Risks, Threats, and Vulnerabilities

Name: _____

Date: _____

Total Points: 100

Time Allowed: 30 Minutes

Instructions

- This quiz contains **20 questions** covering Chapter 3
- Answer all questions to the best of your ability
- Multiple choice questions have only one correct answer
- True/False questions should be marked T or F
- Short answer questions require concise, accurate responses

Section A: Multiple Choice (40 points)

1. (4 points) What is the correct formula for risk?
 - A. $\text{Risk} = \text{Asset} \times \text{Vulnerability}$
 - B. $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$
 - C. $\text{Risk} = \text{Asset} \times \text{Threat}$
 - D. $\text{Risk} = \text{Vulnerability} \times \text{Impact}$
2. (4 points) Which of the following is a weakness in a system that could be exploited by a threat?
 - A. Risk
 - B. Threat
 - C. Vulnerability
 - D. Impact
3. (4 points) What is the output of the risk identification process called?
 - A. Risk Assessment
 - B. Risk Register
 - C. Risk Matrix
 - D. Risk Report
4. (4 points) What does SLE stand for in quantitative risk assessment?
 - A. Security Loss Expectancy
 - B. Single Loss Expectancy
 - C. System Loss Expectancy

- D. Standard Loss Expectancy
5. (4 points) The formula for ALE (Annualized Loss Expectancy) is:
- A. $ALE = AV \times EF$
 - B. $ALE = SLE \times ARO$
 - C. $ALE = \text{Threat} \times \text{Vulnerability}$
 - D. $ALE = \text{Risk} \times \text{Impact}$
6. (4 points) Which type of risk assessment uses relative scales like High, Medium, and Low?
- A. Quantitative risk assessment
 - B. Qualitative risk assessment
 - C. Hybrid risk assessment
 - D. Technical risk assessment
7. (4 points) What is the vulnerability window?
- A. The time between vulnerability announcement and patch application
 - B. The time it takes to identify a vulnerability
 - C. The time a vulnerability remains hidden
 - D. The time to develop an exploit
8. (4 points) A zero-day vulnerability is one where:
- A. No patch exists yet
 - B. The vulnerability is already patched
 - C. The vulnerability only affects zero-day software
 - D. The vulnerability has been known for years
9. (4 points) Which of the following is NOT a type of security control?
- A. Administrative controls
 - B. Technical controls
 - C. Physical controls
 - D. Financial controls
10. (4 points) The dangerous period between the announcement of a vulnerability and when a patch is applied is called:
- A. Risk window
 - B. Vulnerability window
 - C. Threat window
 - D. Security window

Section B: True/False (20 points)

11. (2 points) Risk management is a one-time event, not a continuous process.
- A. True
 - B. False

-
12. (2 points) Qualitative risk assessment is faster but more subjective than quantitative assessment.
- A. True
 - B. False
13. (2 points) The NVD (National Vulnerability Database) enhances CVE data with severity scores.
- A. True
 - B. False
14. (2 points) You should spend more to protect an asset than it is worth.
- A. True
 - B. False
15. (2 points) A threat is the potential for loss or damage to an asset.
- A. True
 - B. False
16. (2 points) Brute-force attacks try every possible password combination.
- A. True
 - B. False
17. (2 points) Spear phishing is a highly targeted form of phishing aimed at specific individuals.
- A. True
 - B. False
18. (2 points) SQL injection is an example of a social engineering attack.
- A. True
 - B. False
19. (2 points) Residual risk is the risk that remains after controls have been applied.
- A. True
 - B. False
20. (2 points) The three main types of threats are disclosure, alteration, and denial/destruction.
- A. True
 - B. False

Section C: Short Answer (40 points)

21. (10 points) Explain the difference between risk, threat, and vulnerability. Provide an example of each.

-
22. (10 points) Describe the quantitative risk assessment process and include the formulas for SLE and ALE.
23. (10 points) List the five steps of the risk management process.
24. (10 points) What are the four common responses to negative risks? Briefly explain each.

End of Quiz